Attacking DNS

The Domain Name System (DNS) translates domain names (e.g., hackthebox.com) to the numerical IP add is mostly UDP/53, but DNS will rely on TCP/53 more heavily as time progresses. DNS has always been desi port 53 from the start, with UDP being the default, and falls back to using TCP when it cannot communica packet size is too large to push through in a single UDP packet. Since nearly all network applications use servers represent one of the most prevalent and significant threats today.

Enumeration

DNS holds interesting information for an organization. As discussed in the Domain Information section in understand how a company operates and the services they provide, as well as third-party service provide

The Nmap -sC (default scripts) and -sV (version scan) options can be used to perform initial enumeration

Attacking DNS

```
dbcyph0n@htb[/htb]# nmap -p53 -Pn -sV -sC 10.10.110.213

Starting Nmap 7.80 ( https://nmap.org ) at 2020-10-29 03:47 EDT
Nmap scan report for 10.10.110.213
Host is up (0.017s latency).

PORT     STATE  SERVICE     VERSION
53/tcp   open   domain      ISC BIND 9.11.3-1ubuntu1.2 (Ubuntu Linux)
```

DNS Zone Transfer

A DNS zone is a portion of the DNS namespace that a specific organization or administrator manages. Si DNS zones, DNS servers utilize DNS zone transfers to copy a portion of their database to another DNS se configured correctly (limiting which IPs can perform a DNS zone transfer), anyone can ask a DNS server f since DNS zone transfers do not require any authentication. In addition, the DNS service usually runs on a

```
inlanefrieght.htb.        604800  IN      SOA     localhost. root.localhost. 2 604800
;; Query time: 28 msec
;; SERVER: 10.129.110.213#53(10.129.110.213)
;; WHEN: Mon Oct 11 17:20:13 EDT 2020
;; XFR size: 8 records (messages 1, bytes 289)
```

Tools like Fierce can also be used to enumerate all DNS servers of the root domain and scan for a DNS zo

Attacking DNS

```
dbcyph0n@htb[/htb]# fierce --domain zonetransfer.me

NS: nsztm2.digi.ninja. nsztm1.digi.ninja.
SOA: nsztm1.digi.ninja. (81.4.108.41)
Zone: success
{<DNS name @>: '@ 7200 IN SOA nsztm1.digi.ninja. robin.digi.ninja. 2019100801 '
               '172800 900 1209600 3600\n'
               '@ 300 IN HINFO "Casio fx-700G" "Windows XP"\n'
               '@ 301 IN TXT '
               '"google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VlMewxA"
               '@ 7200 IN MX 0 ASPMX.L.GOOGLE.COM.\n'
               '@ 7200 IN MX 10 ALT1.ASPMX.L.GOOGLE.COM.\n'
               '@ 7200 IN MX 10 ALT2.ASPMX.L.GOOGLE.COM.\n'
               '@ 7200 IN MX 20 ASPMX2.GOOGLEMAIL.COM.\n'
               '@ 7200 IN MX 20 ASPMX3.GOOGLEMAIL.COM.\n'
               '@ 7200 IN MX 20 ASPMX4.GOOGLEMAIL.COM.\n'
               '@ 7200 IN MX 20 ASPMX5.GOOGLEMAIL.COM.\n'
               '@ 7200 IN A 5.196.105.14\n'
               '@ 7200 IN NS nsztm1.digi.ninja.\n'
               '@ 7200 IN NS nsztm2.digi.ninja.',
 <DNS name _acme-challenge>: '_acme-challenge 301 IN TXT '
                             '"6Oa05hbUJ9xSsvYy7pApQvwCUSSGgxvrbdizjePEsZI"',
 <DNS name _sip._tcp>: '_sip._tcp 14000 IN SRV 0 0 5060 www',
 <DNS name 14.105.196.5.IN-ADDR.ARPA>: '14.105.196.5.IN-ADDR.ARPA 7200 IN PTR '
                                       'www',
 <DNS name asfdbauthdns>: 'asfdbauthdns 7900 IN AFSDB 1 asfdbbox',
 <DNS name asfdbbox>: 'asfdbbox 7200 IN A 127.0.0.1',
 <DNS name asfdbvolume>: 'asfdbvolume 7800 IN AFSDB 1 asfdbbox',
 <DNS name canberra-office>: 'canberra-office 7200 IN A 202.14.81.230',
 <DNS name cmdexec>: 'cmdexec 300 IN TXT "; ls"',
 <DNS name contact>: 'contact 2592000 IN TXT "Remember to call or email Pippa '
                     'on +44 123 4567890 or pippa@zonetransfer.me when making '
                     'DNS changes"',
 <DNS name dc-office>: 'dc-office 7200 IN A 143.228.181.132',
 <DNS name deadbeef>: 'deadbeef 7201 IN AAAA dead:beaf::',
 <DNS name dr>: 'dr 300 IN LOC 53 20 56.558 N 1 38 33.526 W 0.00m',
 <DNS name DZC>: 'DZC 7200 IN TXT "AbCdEfG"',
 <DNS name email>: 'email 2222 IN NAPTR 1 1 "P" "E2U+email" "" '
```

the claimed domain.

Domain takeover is also possible with subdomains called `subdomain takeover`. A DNS's canonical name
different domains to a parent domain. Many organizations use third-party services like AWS, GitHub, Akar
delivery networks (CDNs) to host their content. In this case, they usually create a subdomain and make it
example,

Attacking DNS

```
sub.target.com.   60   IN   CNAME   anotherdomain.com
```

The domain name (e.g., `sub.target.com`) uses a CNAME record to another domain (e.g., `anotherdomain.`
`anotherdomain.com` expires and is available for anyone to claim the domain since the `target.com`'s DNS s
that case, anyone who registers `anotherdomain.com` will have complete control over `sub.target.com` unt

Subdomain Enumeration

Before performing a subdomain takeover, we should enumerate subdomains for a target domain using to
scrape subdomains from open sources like DNSdumpster. Other tools like Sublist3r can also be used to b
supplying a pre-generated wordlist:

Attacking DNS

```
dbcyph0n@htb[/htb]# ./subfinder -d inlanefreight.com -v


        _     __ _         _
____  _| |__ / _(_)_ _  __| |___ _ _
(_-< || | '_ \  _| | ' \/ _  / -_) '_|
/__/\_,_|_.__/_| |_|_||_\__,_\___|_| v2.4.5
                projectdiscovery.io

[WRN] Use with caution. You are responsible for your actions
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[WRN] By using subfinder, you also agree to the terms of the APIs used.

[INF] Enumerating subdomains for inlanefreight.com
[alienvault] www.inlanefreight.com
[dnsdumpster] ns1.inlanefreight.com
[dnsdumpster] ns2.inlanefreight.com
...snip...
[bufferover] Source took 2.193235338s for enumeration
```

```
ns2.inlanefreight.com
www.inlanefreight.com
ms1.inlanefreight.com
support.inlanefreight.com

<SNIP>
```

Sometimes internal physical configurations are poorly secured, which we can exploit to upload our tools f
scenario would be that we have reached an internal host through pivoting and want to work from there. O
alternatives, but it does not hurt to know alternative ways and possibilities.

The tool has found four subdomains associated with `inlanefreight.com`. Using the `nslookup` or `host` co
`CNAME` records for those subdomains.

Attacking DNS

```
dbcyph0n@htb[/htb]# host support.inlanefreight.com

support.inlanefreight.com is an alias for inlanefreight.s3.amazonaws.com
```

The `support` subdomain has an alias record pointing to an AWS S3 bucket. However, the URL `https://su`
shows a `NoSuchBucket` error indicating that the subdomain is potentially vulnerable to a subdomain takeo
subdomain by creating an AWS S3 bucket with the same subdomain name.


This XML file does not appear to have any style information associated with it. The docum

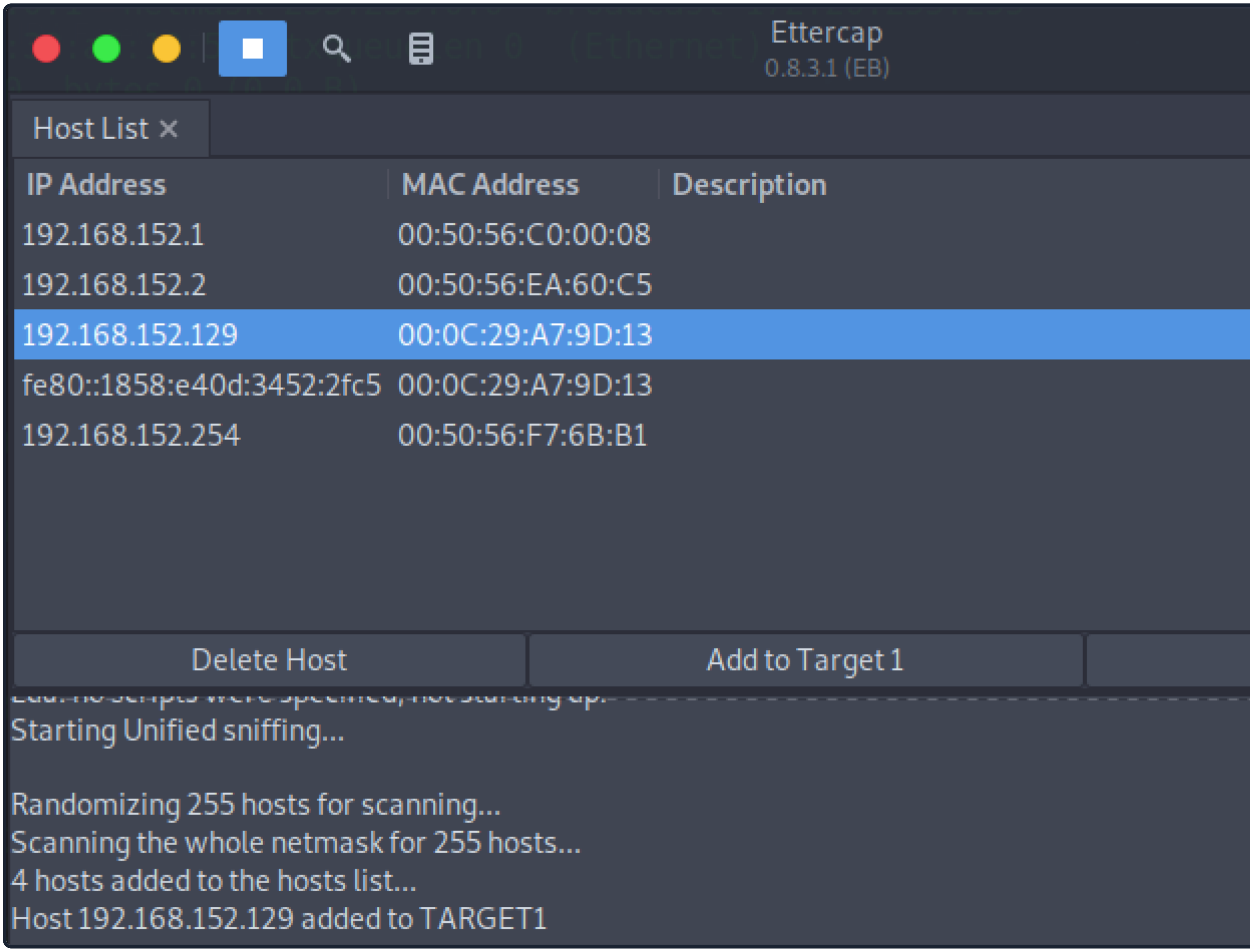
```
▼<Error>
   <Code>NoSuchBucket</Code>
   <Message>The specified bucket does not exist</Message>
   <BucketName>inlanefreight</BucketName>
   <RequestId>TR61BN170VZ3AXN3</RequestId>
   <HostId>8BZc3T/xP+Rzz1TGWYEaufnZuQKe2tqDoxGx7LsfgeyEXoyWWmz2onPByeI36iwD
 </Error>
```

The can-i-take-over-xyz repository is also an excellent reference for a subdomain takeover vulnerability. It
services are vulnerable to a subdomain takeover and provides guidelines on assessing the vulnerability.

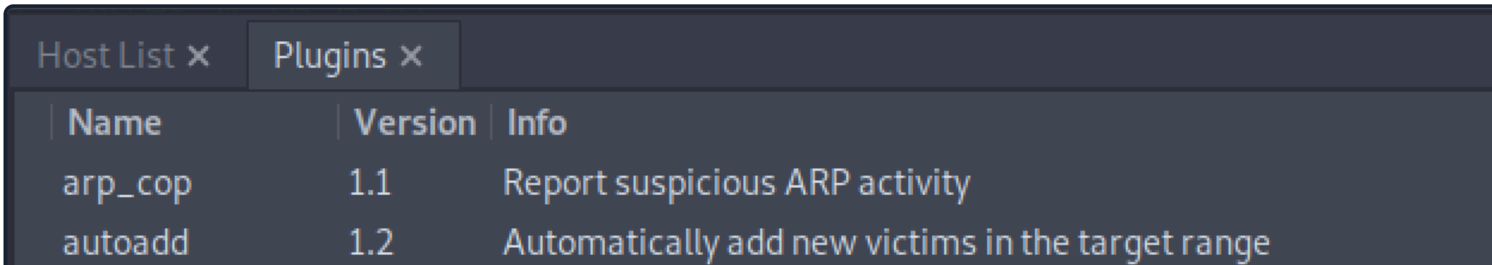
DNS Spoofing

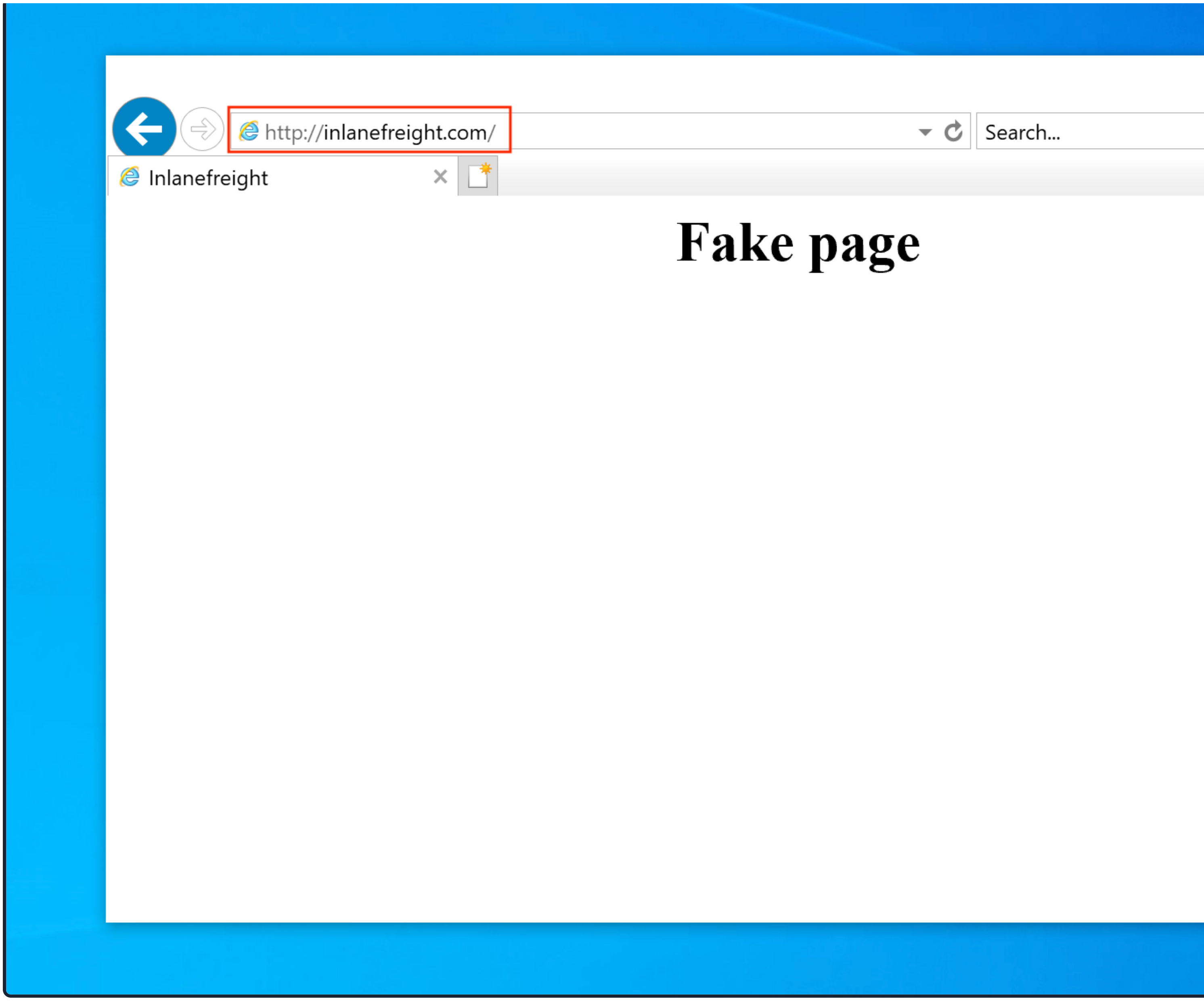
```
dbcyph0n@htb[/htb]# cat /etc/ettercap/etter.dns

inlanefreight.com      A   192.168.225.110
*.inlanefreight.com    A   192.168.225.110
```

Next, start the `Ettercap` tool and scan for live hosts within the network by navigating to `Hosts > Scan fo` the target IP address (e.g., `192.168.152.129`) to Target1 and add a default gateway IP (e.g., `192.168.152.`



Activate `dns_spoof` attack by navigating to `Plugins > Manage Plugins`. This sends the target machine w resolve `inlanefreight.com` to IP address `192.168.225.110`:





In addition, a ping coming from the target IP address `192.168.152.129` to `inlanefreight.com` should be

well:

Attacking DNS

```
C:\>ping inlanefreight.com

Pinging inlanefreight.com [192.168.225.110] with 32 bytes of data:
Reply from 192.168.225.110: bytes=32 time<1ms TTL=64
Reply from 192.168.225.110: bytes=32 time<1ms TTL=64
Reply from 192.168.225.110: bytes=32 time<1ms TTL=64
Reply from 192.168.225.110: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.225.110:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Resources

Go to Questions

Table of Contents

Start Instance

∞ / 1 spawns left